

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

RICARDO DOS SANTOS RIBEIRO FILHO

DOCUMENTAÇÃO DO PROJETO CARRO NÔMADE

Mogi das Cruzes
2026

Sistema: Carro Nômade.

Finalidade: Aluguel de carros.

Registro das Operações de Tratamento de Dados Pessoais.

Inventário de Operações.

Operação A: Cadastro de Novos Clientes.

- **Finalidade:** Permitir que o cliente crie uma conta para alugar carros.
- **Base Legal:** Execução de Contrato.
- **Categorias de Dados:** Nome de usuário, nome completo, email, telefone, senha e confirmar senha.
- **Categoria dos Titulares:** Clientes.

Operação B: Autenticação e Controle de Acesso.

- **Finalidade:** Garantir a identificação e autorização de clientes autenticados para acesso a áreas mais restritas, como histórico de aluguéis, impedindo o acesso de usuários anônimos.
- **Base Legal:** Legítimo interesse ou Execução de Contrato.
- **Dados Tratados:** Login e credenciais de acesso.

Ciclo de Vida e Segurança.

- **Tempo de Retenção:** Os dados serão mantidos enquanto a conta do cliente estiver ativa ou conforme exigência legal de guarda de registros e de prazos prescricionais previstos na legislação civil e tributária.
- **Medidas de Segurança:** Uso de **Hash** para proteção de senhas, proteção de rotas via decorador e prevenção contra ataques **CSRF** em todos os formulários.
- **Compartilhamento:** Os dados não são compartilhados com terceiros.

Governança.

O projeto **Carro Nômade** estabelece este registro como o pilar central de sua conformidade com a **LGPD**, assegurando que todo o tratamento de dados pessoais ocorra de forma transparente e segura. A coleta realizada na **Operação A** é estritamente limitada aos dados de identificação e contato, fundamentando-se na **Base Legal de Execução de Contrato**, uma vez que tais informações são indispensáveis para a formalização do aluguel de veículos. O sistema observa o princípio da minimização, garantindo que nenhum dado sensível ou excessivo seja processado sem finalidade específica.

Em relação à **Operação B**, o tratamento das credenciais de acesso é o mecanismo primário para garantir a **Confidencialidade** e a **Integridade** do sistema, permitindo que apenas clientes devidamente autenticados acessem áreas mais restritas, como históricos de locação, mitigando riscos de acesso por usuários anônimos. A segurança física e lógica desses ativos é reforçada por uma tríade de medidas técnicas: o uso de **Hash** para a proteção irreversível de senhas, a implementação de **decoradores de rota** para controle de acesso no nível da aplicação e a prevenção sistemática contra ataques **CSRF** em todos os formulários de entrada de dados.

Quanto ao ciclo de vida, o **Carro Nômade** adota uma política de retenção rigorosa, mantendo os dados apenas enquanto a conta do cliente estiver ativa ou conforme exigido pelos prazos prescricionais das legislações civil e tributária brasileira. Reforça-se, por fim, o compromisso com a não comercialização de informações, visto que o sistema **não compartilha dados com terceiros**, mantendo o controle absoluto do fluxo informacional dentro de sua infraestrutura controlada.

Política e Aviso de Privacidade.

Política de Privacidade.

1. Escopo e Aplicabilidade.

Esta política detalha as camadas de proteção aplicadas ao ciclo de vida dos dados no sistema. O projeto foi desenvolvido sob o conceito de **Privacy by Design**, assegurando que a privacidade seja uma funcionalidade nativa da arquitetura MVT.

2. Inventário e Minimização.

Em conformidade com o princípio da necessidade, o sistema processa apenas dados estritamente funcionais:

- **Ativos de Identificação:** Nome e e-mail para composição do contrato e comunicação.

- **Ativos de Contato:** Telefone para validação e suporte operacional.
- **Ativos de Autenticação:** Nome de Usuário e senha.

3. Implementação da Segurança.

A governança técnica do sistema é sustentada por três pilares de proteção ativa:

1. **Criptografia de Repouso:** Utilização do algoritmo **PBKDF2** para o hashing de senhas. Esse processo garante que, mesmo em caso de acesso direto à base de dados, as credenciais originais permaneçam ilegíveis.
2. **Defesa de Perímetro de Aplicação:** Uso de decoradores de rota (`@login_required`) em todas as *views* sensíveis, garantindo que relatórios e dados de aluguéis sejam acessíveis apenas por usuários devidamente autenticados.
3. **Integridade de Sessão:** Implementação de tokens **CSRF** em todos os formulários (`form-client`, `form-login`, `form-rent`), mitigando riscos de ataques de falsificação de requisição.

4. Ciclo de Vida e Retenção.

O sistema **Carro Nômade** observa o princípio da limitação do armazenamento, tratando o ciclo de vida dos dados da seguinte forma:

- **Manutenção em Base Ativa:** Os dados de cadastro e credenciais ficam armazenados enquanto a conta do cliente estiver ativa, sendo fundamentais para que o sistema consiga realizar a autenticação e gerenciar os aluguéis.
- **Procedimento de Exclusão:** O cliente que desejar encerrar sua conta deve solicitar a exclusão ao administrador do sistema. Esse processo é realizado manualmente diretamente no banco de dados, garantindo que o hash da senha e os dados de contato sejam removidos da base operacional.

5. Governança e Direitos do Cliente.

O **Carro Nômade** garante ao cliente o controle sobre seus dados através de:

- **Confirmação e Acesso aos Dados:** O cliente tem o direito de solicitar a confirmação da existência do tratamento e o acesso aos seus dados cadastrais. A disponibilização dessas informações é realizada manualmente pelo administrador do sistema mediante solicitação.
- **Correção de Informações:** Caso o cliente identifique dados incompletos ou desatualizados (como e-mail ou telefone), a retificação será processada diretamente na base de dados pelo administrador, garantindo a exatidão dos registros operacionais.

Aviso de Privacidade.

O **Carro Nômade** adota uma postura de transparência no tratamento de dados. Este aviso resume como a plataforma gerencia informações para viabilizar o aluguel de carros.

- **Finalidade:** Gestão operacional de aluguel e autenticação de clientes.
- **Dados Tratados:** Identificação básica (Nome, E-mail, Telefone) e credenciais.
- **Fundamento Legal:** Execução de Contrato.
- **Segurança Técnica:** Proteção de senhas via dispersão criptográfica e controle de sessão.
- **Retenção:** Pelo período de vigência da conta ou prazos legais obrigatórios.

Política de Segurança da Informação.

Objetivo e Escopo.

Esta política estabelece as diretrizes de segurança para a proteção dos ativos de informação do sistema **Carro Nômade**. Ela se aplica a todos os processos de desenvolvimento, armazenamento e manipulação de dados de clientes e automóveis, visando mitigar riscos e garantir a conformidade com a LGPD.

Controle de Acesso Lógico.

O sistema utiliza um modelo de controle de acesso baseado em autenticação obrigatória:

- **Identificação Única:** Cada cliente deve possuir uma credencial exclusiva vinculada ao seu e-mail.
- **Barreiras de Aplicação:** O acesso a funcionalidades críticas (aluguel, relatórios e gestão de frota) é bloqueado por decoradores de autorização (`@login_required`), garantindo que apenas clientes autenticados acessem a camada de lógica de negócios.
- **Gestão de Senhas:** É proibido o armazenamento de senhas em texto claro. O sistema delega a segurança das credenciais ao framework Django, utilizando o algoritmo de dispersão **PBKDF2**.

Segurança no Desenvolvimento.

A integridade do código-fonte e das configurações sensíveis é garantida através de:

- **Versionamento Seguro:** O uso do GitHub para versionamento do código, com a exclusão sistemática de arquivos de configuração local e bancos de dados via arquivo `.gitignore`.

- **Proteção de Segredos:** Chaves de criptografia do framework (`SECRET_KEY`) devem ser tratadas como ativos de alta confidencialidade, não devendo ser expostas em repositórios públicos.

Proteção contra Ameaças da Web.

Para assegurar a integridade das transações, o **Carro Nômade** implementa proteções nativas contra vulnerabilidades do OWASP Top 10:

- **Prevenção de CSRF:** Implementação obrigatória de tokens de validação em todos os formulários de entrada de dados para evitar falsificação de requisições.
- **Prevenção de SQL Injection:** Utilização da camada de abstração de banco de dados (ORM) do Django, que sanitiza automaticamente as consultas.
- **X-Frame-Options:** Proteção contra ataques de *clickjacking* ativa via middleware de segurança, ou seja, o sistema utiliza um middleware de segurança que instrui o navegador do cliente a não renderizar a aplicação dentro de frames de terceiros, mitigando ataques de clickjacking e garantindo que o usuário interaja apenas com a interface legítima.

Segurança dos Dados.

- **Dados em Repouso:** A base de dados deve ser protegida por permissões de sistema de arquivos, limitando o acesso físico ao administrador do sistema.
- **Dados em Trânsito:** Implementa-se o uso de protocolos de transferência segura (HTTPS) para todas as comunicações entre o cliente e o sistema em ambiente de produção.

Gestão de Incidentes e Manutenção.

- **Monitoramento:** O sistema utiliza logs de erro e logs de auditoria do servidor de aplicação para identificar tentativas de acesso não autorizado ou falhas de integridade.

- **Processos Manuais:** Solicitações de exclusão e correção de dados são tratadas de forma administrativa pelo controlador, garantindo a execução da vontade do cliente diretamente na infraestrutura de dados.

Conformidade e Auditoria.

Esta política é revisada periodicamente para alinhar-se às evoluções do projeto. O descumprimento das diretrizes aqui estabelecidas sujeita o responsável às sanções administrativas e legais previstas na LGPD e no Código Civil Brasileiro.

Compromisso com a Melhoria Contínua.

A Segurança da Informação não é um estado estático, mas um processo contínuo de adaptação e vigilância. Esta política reflete o compromisso do administrador com a preservação da tríade **CID (Confidencialidade, Integridade e Disponibilidade)**.

Embora certas funcionalidades ainda não estejam devidamente implementadas no projeto Carro Nômade, as diretrizes aqui estabelecidas garantem que todos os processos manuais e administrativos sigam os mais rigorosos padrões de proteção de dados. A evolução técnica do sistema buscará, de forma incessante, a melhoria de todas estas funções, mantendo sempre a transparência e a ética no tratamento dos ativos de informação dos clientes.

Relatório de Impacto à Proteção de Dados.

1. Metodologia e Escopo do Processamento.

Este documento apresenta a análise de impacto referente ao ciclo de vida dos dados na aplicação **Carro Nômade**, desenvolvida em **Django**. O processamento baseia-se na coleta de dados de identificação de **Clientes** para fins de aluguel de carros. A metodologia adotada segue os princípios de *Privacy by Design*, integrando controles de segurança desde a concepção do código até o armazenamento final em banco de dados. O fluxo compreende a captura de dados via HTTPS, processamento em servidor de aplicação e armazenamento persistente com proteção de credenciais.

2. Análise de Necessidade e Proporcionalidade.

A coleta de dados pelo sistema fundamenta-se estritamente no princípio da **Finalidade**, sendo a identificação do cliente um requisito essencial para a viabilidade jurídica e operacional do contrato de aluguel. O **Carro Nômade** observa o princípio da **Minimização**, limitando o tratamento aos dados de nome, contato e credenciais, sem resultar na coleta de dados sensíveis ou excessivos. A retenção das informações é pautada pela duração da relação contratual e pelos prazos prescricionais previstos no Código Civil para a guarda de registros comerciais.

4. Implementação de Medidas de Segurança.

Para garantir a **Confidencialidade** e **Integridade**, o sistema utiliza um modelo de controle de acesso rigoroso que atua como um firewall de aplicação no nível das *views*, bloqueando requisições não autenticadas a rotas administrativas. A proteção contra ataques de força bruta é reforçada pelo armazenamento de

senhas em formato de hash unidirecional, impedindo a leitura direta das credenciais no banco de dados. Adicionalmente, todos os formulários de entrada de dados, como o `form_client` e o `form_login`, possuem validação de integridade via tokens de segurança para prevenir injeções maliciosas.

4.1. Monitoramento, Auditoria e Resposta a Incidentes.

A manutenção da **Disponibilidade** e da **Integridade** dos dados no sistema **Carro Nômade** não se limita apenas às barreiras de entrada. Foi implementada uma estratégia de monitoramento através dos logs de auditoria nativos do framework **Django**, que registram tentativas de acesso malsucedidas e transações críticas no banco de dados. Em caso de detecção de anomalias ou indícios de invasão, o protocolo de resposta a incidentes prevê o isolamento imediato da base de dados e a notificação dos clientes, conforme exigido pelo Artigo 48 da LGPD. Essa camada de governança técnica assegura que o sistema não apenas proteja os dados, mas que seja capaz de reagir a vetores de ataque em tempo real.

4.2. Governança de Dados e Privacy by Default.

O desenvolvimento seguiu rigorosamente os preceitos de *Privacy by Default*, garantindo que as configurações de privacidade mais restritivas sejam aplicadas automaticamente a cada novo cadastro de cliente. O sistema foi implementado para evitar que informações sensíveis sejam processadas em áreas de cache ou expostas em logs de erro do servidor de aplicação. Além disso, a arquitetura **MVT** do Django é utilizada para garantir a higienização de todos os inputs de dados, protegendo o banco de dados contra ataques de **SQL Injection**, o que reforça a segurança física e lógica dos ativos de informação do projeto.

4.3. Gestão de Direitos dos Clientes.

O Carro Nômade estabelece diretrizes para viabilizar a transparência e o exercício dos direitos dos clientes conforme a legislação vigente. O fluxo atual para solicitações de acesso, retificação ou exclusão definitiva de dados ocorre

por meio de intermediação administrativa. Na fase atual do projeto, o administrador não realiza mais o processamento dessas demandas manualmente na infraestrutura de banco de dados, garantindo a eliminação segura das informações e das credenciais de acesso, observando-se as restrições impostas pelas obrigações de retenção legal e prazos prescricionais. Essa metodologia assegura que o ciclo de vida dos dados seja auditável e esteja em conformidade com as exigências de governança e segurança da informação estabelecidas.

Política de Cookies.

1. Objetivo e Escopo.

Esta política descreve como o sistema Carro Nômade utiliza cookies e tecnologias semelhantes para garantir a funcionalidade técnica, a segurança e a experiência do cliente. Como o projeto utiliza o framework Django, os cookies são essenciais para manter a integridade das sessões e proteger o sistema contra ataques cibernéticos.

2. O que são Cookies?

Cookies são pequenos arquivos de texto armazenados no navegador do cliente quando este acessa a aplicação. Eles permitem que o servidor reconheça o cliente em requisições subsequentes, mantendo o estado da navegação (como o login ativo).

3. Categorias de Cookies Utilizados.

Em conformidade com o princípio da Minimização da LGPD, o Carro Nômade utiliza exclusivamente Cookies Estritamente Necessários. Não são utilizados cookies de publicidade, rastreamento de terceiros ou perfis de comportamento.

3.1. Cookies de Sessão e Autenticação.

Estes cookies são fundamentais para que o sistema identifique o usuário (cliente) logado enquanto ele navega entre diferentes páginas (ex: da lista de carros para o formulário de aluguel). Sem eles, o decorador `@login_required` exigiria login a cada clique, inviabilizando o uso do sistema.

3.2. Cookies de Segurança (CSRF).

O sistema utiliza cookies para armazenar tokens de proteção contra ataques de Falsificação de Requisição entre Sites (CSRF). Este mecanismo garante que as ações realizadas (como cadastrar um cliente ou confirmar um aluguel) foram de fato originadas pelo cliente legítimo dentro da aplicação.

1. Gestão e Controle pelo Cliente.

O cliente não pode configurar seu navegador para bloquear ou excluir cookies. Ou seja, a desativação dos cookies estritamente necessários impedirá o acesso

às funcionalidades de autenticação e reserva do **Carro Nômade**, uma vez que a segurança e a manutenção da sessão dependem dessas tecnologias.

2. Conformidade e Atualização.

Esta política é parte integrante da governança de dados do projeto e é revisada conforme novas funcionalidades técnicas forem implementadas. O uso do sistema implica na ciência do processamento desses cookies técnicos, indispensáveis para a **Execução de Contrato e Legítimo Interesse** de segurança.

Termos de Uso.

Aceitação e Objetivo.

O sistema **Carro Nômade** é uma plataforma destinada à gestão de aluguéis de veículos (carros). Ao realizar o cadastro e utilizar as funcionalidades do sistema, o usuário (Cliente) concorda integralmente com as condições aqui

estabelecidas. Este projeto possui fins acadêmicos, representando um Produto Mínimo Viável (MVP) em constante evolução.

Cadastro e Segurança das Credenciais.

- **Veracidade dos Dados:** O Cliente compromete-se a fornecer informações exatas (Nome, E-mail e Telefone). O fornecimento de dados falsos pode resultar no bloqueio administrativo da conta.
- **Confidencialidade da Senha:** A senha é pessoal e intransferível. O sistema utiliza hashing **PBKDF2**, garantindo que nem mesmo o administrador tenha acesso à senha em texto claro. O Cliente é o único responsável por manter a segurança de seu acesso.
- **Uso da Conta:** Cada conta é individual. O uso de scripts automatizados para acesso ou manipulação de dados é terminantemente proibido.

Condições de Uso do Sistema.

O Cliente declara estar ciente de que:

- **Disponibilidade:** Por se tratar de um ambiente de desenvolvimento e prototipagem acadêmica, o sistema pode apresentar instabilidades ou períodos de manutenção sem aviso prévio.
- **Funcionalidades:** O sistema permite a listagem de automóveis (carros), simulação de aluguéis e geração de relatórios. O uso indevido dessas ferramentas para fins ilícitos acarretará a exclusão do acesso.

Limitação de Responsabilidade.

O desenvolvedor e administrador do sistema não se responsabiliza por:

1. Danos decorrentes de mau uso da plataforma pelo Cliente.
2. Interrupções de serviço causadas por falhas na infraestrutura de hospedagem ou conectividade.
3. Ações de terceiros que explorem vulnerabilidades de segurança decorrentes de senhas fracas ou compartilhadas pelo próprio Cliente.

Encerramento e Exclusão de Dados.

Conforme a Política de Privacidade, a funcionalidade de exclusão de conta ainda deve ser implementada. O Cliente que desejar excluir sua conta e solicitar a exclusão definitiva de seus dados deve entrar em contato com o administrador para que o procedimento seja realizado manualmente na base de dados.

Propriedade Intelectual.

Toda a lógica de negócios, arquitetura Django, modelos de banco de dados e interface do **Carro Nômade** são de propriedade intelectual do administrador. A engenharia reversa ou a reprodução não autorizada do código-fonte é proibida.

Considerações.

Este Termo de Uso é regido pelas leis da República Federativa do Brasil. O **Carro Nômade** reserva-se no direito de atualizar este documento conforme a evolução das funcionalidades e requisitos de segurança do sistema, sempre visando a melhoria da experiência do Cliente e a conformidade com as diretrizes de Segurança da Informação.

Eventuais dúvidas ou solicitações de suporte em relação ao uso do sistema devem ser encaminhadas ao administrador. O uso contínuo da plataforma após qualquer alteração nestes termos constitui a aceitação das novas condições.

Relatório de Inventário de Dados.

Identificação e Escopo.

Este relatório apresenta o inventário detalhado dos ativos de dados pessoais tratados pelo sistema **Carro Nômade**. O objetivo é catalogar todas as informações coletadas, processadas e armazenadas, garantindo a rastreabilidade e a transparência exigidas pela **LGPD**. O escopo abrange desde a coleta no *Front-End* via formulários Django até a persistência no banco de dados relacional.

Classificação e Tratamento.

O sistema **Carro Nômade** adota uma política de classificação de dados rigorosa, onde as informações são separadas entre dados de identificação comum e credenciais de segurança. Observa-se que o sistema **não realiza a coleta de dados sensíveis**, tais como origem racial, convicção religiosa ou dados de saúde, o que reduz significativamente o risco biográfico do cliente.

As credenciais de acesso recebem tratamento de **Alta Sensibilidade**, sendo submetidas a um processo de dispersão criptográfica antes de qualquer operação de escrita no sistema, impossibilitando a reversão dos dados em caso de acesso indevido à infraestrutura de banco de dados. O fluxo de dados é estritamente interno, operando sob o princípio da necessidade, onde apenas as *views* autenticadas possuem permissão de leitura sobre os registros de aluguel e perfis de clientes.

Ciclo de Vida e Armazenamento.

O ciclo de vida dos ativos no sistema **Carro Nômade** é realizado pelos princípios da **Integridade** e da **Disponibilidade**, estruturando-se em quatro etapas fundamentais: coleta, processamento, armazenamento e manutenção. A persistência dos dados ocorre em ambiente controlado, utilizando o banco de dados relacional, o que garante a aplicação automática de camadas de abstração de banco de dados que previnem vulnerabilidades de injeção. O armazenamento observa o conceito de *Privacy by Default*, onde as credenciais de acesso, classificadas como ativos de alta sensibilidade, são submetidas a processos de derivação de chave e **hashing** antes da gravação física no sistema, assegurando que a informação original seja irrecuperável mesmo em cenários de infiltração na base de dados.

A manutenção e retenção desses dados são pautadas por uma política de governança que equilibra a utilidade operacional e a conformidade legal. As informações cadastrais e os registros de locação permanecem ativos enquanto houver uma relação contratual vigente com o cliente. No entanto, o encerramento de uma conta não implica necessariamente na exclusão imediata de todos os registros.

O sistema observará os **prazos prescricionais** previstos no Código Civil e na legislação tributária brasileira, que exigem a guarda de documentos e registros financeiros por períodos que podem variar de cinco a dez anos para fins de fiscalização e exercício regular de direitos em processos judiciais.

